

VDA-MD FRAMEWORK

Value-Driven-AI Markdown Engine V4.0

mikerawsonnz@gmail.com

AI operations and governance your whole organisation can read, own, and trust.

Translating business logic and global compliance standards into human-readable, domain-owned, agent-actionable Markdown — governed by the customer journey that already exists in every organisation.

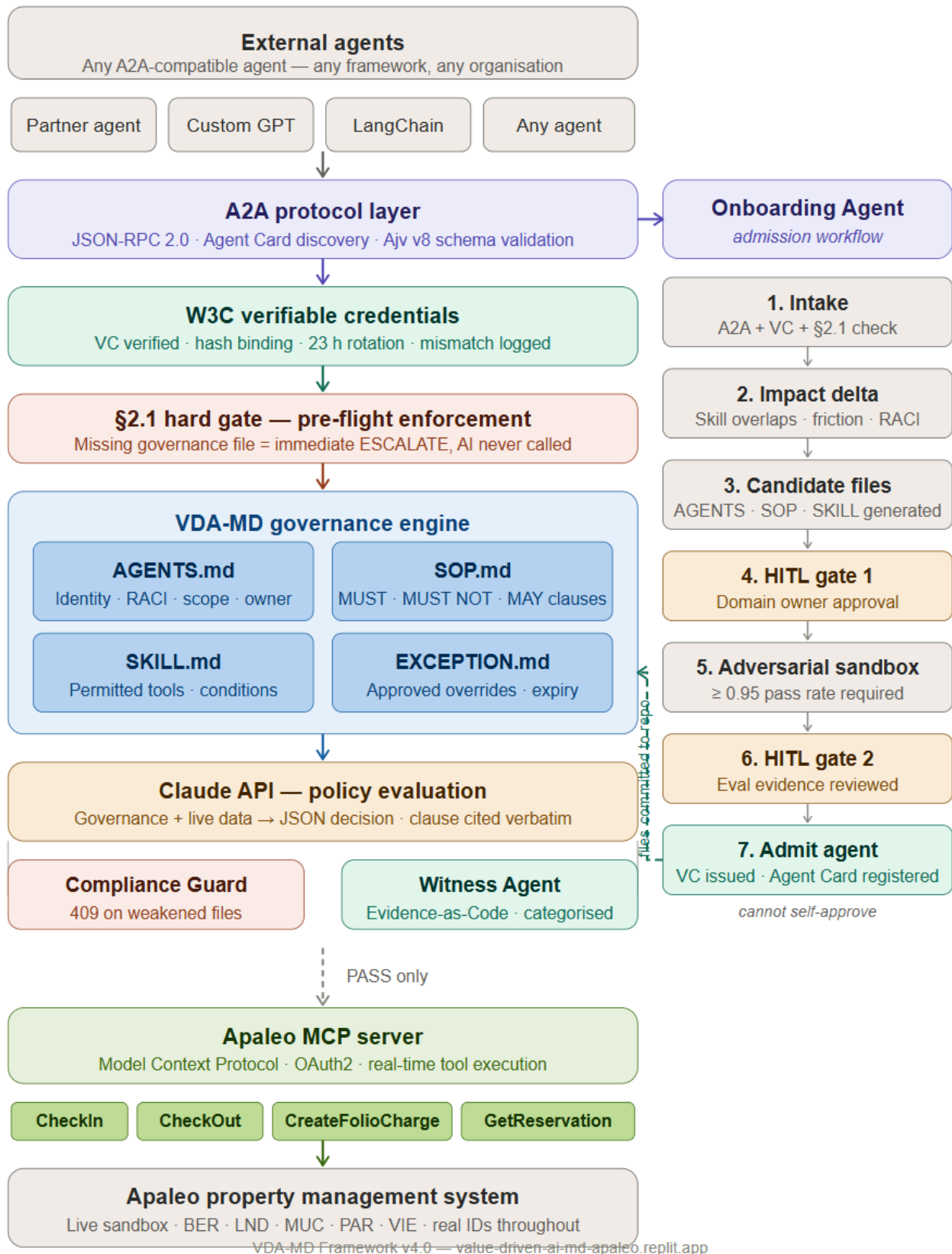
Document Type
Technical Whitepaper v4.0
Date
April 2026
Classification
Confidential
Live Demo
value-driven-ai-md-apaleo.replit.app

For clarity: VDA-MD framework governs in plain English the compliance, rules and business logic (the What). The A-Wrapper (separate framework (the How)) addresses the execution architecture, cost modelling, and infrastructure failsafes.

Architecture Overview

The VDA-MD Framework operates across four foundational layers — from raw compliance input to continuous audit output. In version 4.0, four new capability layers extend this foundation: cryptographic agent identity, A2A external agent interoperability, self-governing agent onboarding, and a fully categorised audit system with integrity monitoring.

No business logic for agent decisions is hardcoded in application code. Every threshold, every authority boundary, every compliance rule, and every exception condition lives in a Markdown governance file loaded at runtime.



Layer	Component	Function
1 — Ingestion	C2MD Pipeline	Translate NIST OSCAL, ISO 42001, and APQC into structured Markdown baseline files. Brand and exception documents ingested via Microsoft Presidio (PII-scrubbed) then Markdown.
2 — Storage	Two-Axis Governance Map	Industry-specific customer journey encoded as a Markdown matrix with RACI in file structure. Vertical axis = customer journey stages. Horizontal axis = Shared Services value streams (S2P, O2C, HRpay).
3 — Execution	Agent Runtime	Agents load AGENTS.md + SOP.md + SKILL.md at runtime. Missing any file = immediate ESCALATE before AI is called. EXCEPTION.md overlays applied conditionally. MUST/MUST NOT clauses provide strong guardrails.
4 — Audit	Witness Agent	Every decision sealed to a structured, categorised audit log: exact clause applied, file referenced, live data context, escalation target, event category. Compliance Guard enforces file integrity on every save.
5 — Identity	W3C Verifiable Credentials	Every agent holds a cryptographically signed credential binding its identity to its current governance file hash. Credentials rotate every 23 hours. Hash mismatch = immediate audit event.
6 — Transport	A2A Protocol	Google DeepMind Agent-to-Agent Protocol (JSON-RPC 2.0) enables any external AI agent to discover and interact with VDA-MD governed agents. Ajv v8 schema validation on every incoming message.
7 — Lifecycle	Onboarding Agent	A 9th governed agent manages external agent admission via a 7-phase workflow with impact delta analysis, dual HITL gates, adversarial sandbox evaluation, and full rollback capability.

Executive Summary

Gartner predicts that more than 40% of enterprise agentic AI projects will be cancelled by the end of 2027, citing escalating costs, unclear business value, and inadequate risk and compliance controls as the primary causes (Gartner, June 25, 2025 — Emerging Tech: Avoid Agentic AI Failure: Build Success Using Right Use Cases). The primary cause is not model quality, and it is not governance alone. Most projects fail for mundane economic and strategic reasons: capital deployed against the wrong use cases, ROI frameworks that cannot accommodate the complexity of agentic systems, and organisations that simply do not yet know how to manage autonomous AI at scale. Governance — specifically the absence of a practical, scalable mechanism for encoding business logic and organisational rules into a form AI agents can reliably act upon — is a significant contributing factor, and the one this framework directly addresses. If the rules themselves are poorly conceived, no governance tooling will save them.

The VDA-MD Framework (Value-Driven-AI Markdown Engine) addresses the governance dimension of this problem through a single architectural principle validated by thirty years of enterprise technology implementation: establish industry-specific customer journey and global best-practice standards as an automated baseline, and use AI to govern only what makes each organisation genuinely unique — its brand personality, operational exceptions, and domain-specific rules. Everything that is structurally identical across organisations in the same industry is pre-built. Only the genuine secret sauce requires ingestion.

While 78% of organisations use AI in at least one business function, only 25-36% have implemented formal governance frameworks — a gap confirmed across AuditBoard, Pacific AI, and McKinsey's 2025 research. The tools that exist are wrong for the problem: built for compliance officers, not domain owners; producing reports, not governance files; monitoring humans, not governing agents.

At the core of the framework is C2MD (Compliance to Markdown) — a named, structured, repeatable methodology that uses large language models to translate machine-readable compliance standards (NIST OSCAL, ISO 42001, APQC) into structured, human-readable Markdown files that serve as the operational governance layer for AI agents at runtime.

Version 4.0 adds four major capability layers that significantly strengthen the framework's governance posture while increasing operational flexibility:

- **Cryptographic Agent Identity** — W3C Verifiable Credentials bind every agent's identity to the exact governance files it was authorised to operate under. Credentials rotate every 23 hours. If governance files change, the hash mismatch is detected immediately and recorded in the tamper-evident audit trail.
- **A2A External Interoperability** — Google DeepMind's Agent-to-Agent Protocol enables external AI agents from any organisation or framework to interact with VDA-MD governed agents through a standards-compliant JSON-RPC 2.0 interface, with Ajv v8 schema validation on every message.
- **Self-Governing Agent Onboarding** — A 9th agent governs its own framework's growth. New agents are admitted through a 7-phase workflow including impact delta analysis, dual human approval gates, and an adversarial governance sandbox evaluation. The framework governs itself using the same rules it applies to everything else.
- **Witness Agent Governance Expansion** — The audit trail now categorises every event by governance domain, a 6-hour integrity check scheduler runs automatically, and a Framework Integrity Panel surfaces live compliance metrics to platform operators.

The framework has been validated as a working platform — VDA-MD (Value Driven AI Management Kit) — built on top of the Apaleo Property Management System and tested against Apaleo's sandbox environment across five citizenM hotel properties. Hospitality is the

proof-of-concept vertical. The framework is designed for any industry with a defined customer journey.

The validation produced two architectural findings not anticipated in the original design: a Compliance Guard that enforces governance file integrity deterministically at the application layer, and a §2.1 Enforcement Rule that prevents any agent from operating outside its governance envelope before AI is ever called. These findings, confirmed in v4.0 across all capability layers, establish that governance file integrity and governance envelope enforcement can be achieved deterministically in the standalone tier without enterprise OPA infrastructure.

1. The Problem: Process Debt and the AI Governance Gap

1.1 The Failure Rate Nobody Is Talking About

Gartner's June 2025 analysis predicts over 40% of agentic AI projects will be cancelled by end of 2027, with escalating costs, unclear business value, and inadequate risk controls as the stated causes. This failure is architectural and organisational — but not exclusively so. The honest reading of the data is that many projects fail because they are the wrong projects: hype-driven experiments, misapplied use cases, and what Gartner terms agent washing — rebranding existing automation as agentic AI without delivering genuine autonomy. Governance tooling is part of the solution, not all of it.

The VDA-MD Framework addresses the governance and operational accountability dimension of this failure pattern — the absence of a mechanism for encoding organisational rules into a form that AI agents can reliably act upon. It does not claim to solve cost discipline or strategic clarity, which remain the responsibility of the organisations deploying it (refer A-Wrapper framework separately for enterprise execution architecture).

1.2 The Three Root Causes

Process Debt

Decades of operational rules — from VIP customer handling to supplier approval thresholds to employee onboarding procedures — are trapped in static, fragmented folders of PDFs, Word documents, and Excel sheets. These documents are not machine-readable. An AI agent cannot reliably govern its own behaviour against a 200-page PDF operations manual. Previous attempts to solve this by ingesting all process documentation have failed at cost and quality — the process debt is simply too large.

The Governance Technology Gap

Existing AI governance platforms (Credo AI, OneTrust, IBM Watsonx.governance, Collibra) are built for enterprise compliance officers with dedicated teams and large budgets. They produce dashboards that executives review, not systems that domain owners operate. They are passive monitoring tools, not active governance engines. None of them make the hotel General Manager, the clinic owner, or the VP of Operations the actual operator of their AI governance.

The Compliance-to-Execution Disconnect

Compliance frameworks (NIST SP 800-53, ISO 42001, APQC process standards) exist in machine-readable formats (OSCAL XML, JSON). Policy enforcement engines (OPA, Kyverno) exist and are mature. But the bridge between compliance standards and runtime agent governance does not exist as a practical, deployable system. The Compliance-to-Policy (C2P) project generates Kubernetes infrastructure policies; it does not generate agent governance files that a business owner can read and a domain AI can act upon. And it does not incorporate business logic in the same place.

THE GAP

While 78% of organisations use AI in at least one business function, only 25-36% have implemented formal governance frameworks — a gap confirmed across AuditBoard, Pacific AI, and McKinsey's 2025 research. The tools that exist are wrong for the problem: built for compliance officers, not domain owners; producing reports, not governance files; monitoring humans, not governing agents.

McKinsey's June 2025 research on agentic AI found that while nearly two-thirds of enterprises worldwide have experimented with agents, fewer than 10% have scaled them to deliver tangible value — and eight in ten companies cite data limitations as a roadblock to scaling. QuantumBlack (McKinsey's AI arm) identifies the most common unstructured data quality problems as: diverse document formats hard to parse; lack of metadata tags making search and retrieval difficult; siloed storage across business units; conflicting information in multiple versions; and sensitive information ingested without proper filtering or access control.

2. The VDA-MD Framework: Core Architecture

2.1 The Founding Principle: Baseline Industry Best Practice Plus Delta

The VDA-MD Framework is built on a single architectural principle: establish global best-practice industry standards as the automated baseline, and govern only the genuine delta — the exceptions, brand rules, and operational deviations that make each organisation unique. This is not a new idea. BPR in the 1990s, ERP in the 2000s, and Knowledge Management in the 2010s all failed at scale because they attempted to capture and digitise all organisational knowledge. The task is too large, too expensive, and too slow.

The VDA-MD inverts this model. An industry-defined, pre-configured, AI-generated baseline of global best practices anchored to NIST OSCAL, ISO 42001, and APQC process standards covers the 80% of organisational behaviour that is structurally identical across all companies in the same industry. The ingestion engine is then deployed exclusively to capture the 20% that makes each organisation genuinely unique. Where this delta has gaps, a domain-expert Human In the Loop will correct it.

The baseline must never be created by AI alone. The human approval gate is not optional — it is the quality control mechanism that validates translation fidelity. If the source compliance document is required to understand the generated governance file, the translation has failed.

2.2 Industry Agnosticism: Any Journey, Any Domain

The hospitality implementation validated in this document is a proof of concept, not a constraint. The framework's architecture is built around the customer journey — the sequence of stages through which any organisation delivers value to its customers. This structure exists in every industry:

Industry	Journey Stages	Governance Domains
Healthcare	Referral → Triage → Consultation → Treatment → Follow-up → Discharge	Patient admissions, clinical decision support, billing compliance
Financial Services	Onboarding → KYC → Product Selection → Servicing → Review	Credit decisions, regulatory reporting, fraud detection
Legal Services	Intake → Due Diligence → Advice → Execution → Archive	Conflict checking, matter management, privilege compliance
Retail	Discovery → Selection → Purchase → Fulfilment → Return	Pricing authority, inventory management, returns policy
Professional Services	Scoping → Engagement → Delivery → Invoicing → Review	Engagement governance, billing approval, IP protection
Hospitality (POC)	Pre-Book → Book → Stay → Post-Stay	Availability, reservations, operations, revenue reconciliation

The Three Universal Horizontal Value Streams (Source-to-Pay, Order-to-Cash, Onboarding-to-Final-Pay) apply identically across all of these industries. Pre-built C2MD baselines for these value streams are genuinely comprehensive before a single customer document is ingested.

2.3 Markdown as the Governance Primitive

The strategic choice of Markdown as the universal governance format is not a technical convenience — it is the architectural insight that makes the entire system work. Markdown serves simultaneously as:

- A human-readable format that a VP of Operations, a Compliance Officer, or a hotel General Manager can read, understand, and edit without technical training.
- The native instruction layer for large language models. LLMs are directly trained on Markdown because a substantial portion of high-quality training data originates from GitHub, Stack Overflow, and technical documentation — Markdown provides semantic anchors that models can leverage to reason about structured information (Kubicek, 2026). The practical efficiency advantage is well-attested: converting to clean Markdown reduces token consumption by 20-50% compared to raw HTML or unstructured formats (SearchCans; Kubicek).
- A versionable, diffable, committable artefact that Git treats as first-class text, providing the audit trail that compliance frameworks require.
- A format that makes agent instructions explicit and auditable, reducing but not eliminating the risk of misinterpretation. Markdown governance files constrain agent behaviour; they do not deterministically enforce it at the network layer. The enterprise configuration adds OPA Rego as a second enforcement layer; the standalone configuration uses the Compliance Guard and mandatory human-in-the-loop for high-risk decisions.
- A vendor-independent format: plain text, readable by any editor, versionable by any Git provider, consumable by any LLM, and migratable to any future platform without conversion.

A single .md file simultaneously satisfies the needs of three different audiences: the business owner who authors it, the AI agent that governs itself against it at runtime, and the auditor who reviews it as compliance evidence.

2.4 The Four Core File Types

File Type	Purpose	Description
AGENTS.md	Agent Charter	Defines agent identity, scope of authority, RACI ownership structure, and inheritance hierarchy. Contains the agent's cryptographic identity binding (agentId field referenced by the VC layer).
SOP.md	Standard Operating Procedure	Human-readable policy containing all MUST, MUST NOT, and MAY clauses that govern agent decisions — the machine-readable rulebook. The agent must cite the verbatim clause that governed its decision.
SKILL.md	Skill Manifest	Defines the capabilities the agent is permitted to exercise — the actions it may take, the conditions under which each is permitted, and the specific execution methods through which each is delivered. The VC governance hash is computed over these three mandatory files.
EXCEPTION.md	Exception Overlay	Approved deviations from the baseline, with owner, expiry, approval metadata, and explicit reversion conditions.

		Applied on top of the SOP without replacing it. When active, the agent must cite the EXCEPTION clause verbatim.
--	--	---

3. Governance in Practice: The Complete Loop

The following real governance files and Witness Agent entries from the citizenM Hospitality POC illustrate the complete governance loop: rule defined, exception applied, decision logged. Two agents, same rule, same morning — different outcomes determined entirely by file content.

BASELINE — hospitality-stay-checkout.md

```
control_id: hospitality-stay-checkout
domain: Operations / Stay
owner: Operations Director
nist_control: AU-2

## Guest Checkout Policy — Baseline
Standard checkout at all citizenM properties: 11:00 AM.

### Agent Rules
- MUST check housekeeping availability before offering any late checkout
- MUST NOT waive the late checkout fee without Operations Director authorisation
- MUST log all checkout modification requests in PMS
- MUST confirm valid departure date before any modification
```

EXCEPTION OVERLAY — hospitality-stay-VIP-checkout-exception.md

```
exception_to: hospitality-stay-checkout
applies_to: citizenM Black membership tier
conditions: EMEA properties only — checkout MUST NOT exceed 14:00
approved_by: COO | expires: 2026-12-31 | risk_level: low

### Agent Rules (Override)
- MAY grant checkout to 14:00 without fee for verified Black members
- MAY skip availability check for verified Black members
- MUST verify active Black status in CRM before applying
- MUST NOT extend beyond 14:00 under any circumstance
- MUST log exception application in the Witness trail
```

Witness Agent Log — Same Morning, Two Decisions

Timestamp	Agent	Outcome	Clause Applied
07:14:38	Stay Agent — Amsterdam	PASS — exception applied	MAY grant checkout to 14:00 without fee for verified Black members
10:08:03	Stay Agent — Glasgow	FAIL — escalation triggered	MUST NOT waive late checkout fee without Operations Director authorisation

The Amsterdam agent applied the exception correctly — Black member verified, EMEA property, checkout within 14:00. The Glasgow agent hit the baseline — no exception conditions met, fee waiver blocked, escalation triggered automatically. The Witness Agent logged both decisions including the exact clause and file that governed each outcome. The auditor's question — prove this checkout was handled correctly — is answered by the log entry alone.

This is what structured MUST/MUST NOT governance achieves that prose instructions do not: the agent's decision space is fully determined. There is no interpretive gap for probabilistic reasoning to fill.

4. C2MD: Compliance to Markdown

4.1 What C2MD Is

The practice of using large language models to translate compliance standards into operational instructions, and of using Markdown as an AI agent instruction layer, has existed informally in practitioner communities for several years. Agentic personal knowledge management — structuring organisational knowledge in Markdown for AI consumption — is an established approach, not an invention of this framework.

What C2MD introduces is a unique combined approach: a named, structured, repeatable methodology that defines the translation direction (compliance standard to human-readable governance file), the output taxonomy (AGENTS.md, SOP.md, SKILL.md, EXCEPTION.md), the ownership model (domain owner as author and accountable party, not platform engineering), the baseline-plus-delta architecture, and the audit mechanism (RACI encoded in YAML front matter, Witness Agent producing Evidence-as-Code).

A practitioner already governing AI agents with Markdown files can adopt C2MD by applying the taxonomy and ownership model to what they are already doing — there is an import feature called A2MD which will normalise a non-VDA-MD file. Formalisation is not the same as invention, but it is what makes a practice scalable.

4.2 C2MD Versus C2P

Dimension	C2P (Compliance to Policy)	C2MD (Compliance to Markdown)
Translation direction	OSCAL → Kyverno / Ansible / OPA Rego	OSCAL → structured human-readable .md
Output audience	Policy enforcement engines (machines)	Domain owners (humans) + AI agents
Output editability	Requires Rego/YAML expertise to modify	Any domain owner can read and edit
Runtime role	Infrastructure enforcement (Kubernetes clusters)	Agent governance baseline (LLM runtime)
Ownership model	Platform engineering team	VP of Operations, Compliance Officer, GM
Audit artefact	Machine-generated policy bundles	Human-approved, version-controlled .md files
Baseline coverage	IT infrastructure controls	All operational domains including S2P, O2C, HR

In the enterprise configuration, C2MD and C2P are sequential stages, not alternatives. C2MD produces the human-readable Markdown governance files that domain owners can read, edit, and approve. A subsequent automated step compiles those approved Markdown files into OPA Rego policies for deterministic enforcement at the network layer. The Markdown remains the source of truth; the Rego is a derivative artefact generated from it.

4.3 Why LLMs Are the Right Tool for C2MD

Large language models have deep, accurate training on NIST SP 800-53, ISO 42001, APQC, SOC2 process frameworks, and related compliance standards. This training means the model

does not need to parse OSCAL XML through a plugin architecture to understand what a control requires. It understands the control semantically, including its enhancement clauses, implementation guidance, and operational implications.

Large language models are probabilistic systems. Hallucination, silent failure, and edge case misinterpretation are construction properties of current AI — not instruction errors that better prompting will eliminate. The VDA-MD governance file format directly addresses this by using normative constraint language — MUST, MUST NOT, explicit escalation triggers, and precise violation definitions. An agent given a MUST NOT rule with an explicit escalation path does not need to infer what to do; it has a binary test to apply.

4.4 The C2MD Translation Pipeline

1. Input ingestion: The NIST OSCAL JSON control (or ISO 42001 clause, or APQC process definition) is provided as structured context to the LLM, along with vertical domain context and the specific operational area.
2. Semantic translation: The LLM translates the control from regulatory language into operational language appropriate for the domain. The OSCAL control ID and framework reference are preserved in YAML front matter.
3. Agent rule extraction: The LLM extracts explicit agent decision rules — what the agent must check before acting, what constitutes a violation, what requires human approval.
4. Confidence scoring: Each translated clause receives a confidence score. Clauses below threshold are flagged for human review, ensuring that complex multi-part controls are not silently oversimplified.
5. Human approval gate: The Compliance Officer reviews flagged clauses, corrects where necessary, and approves. The approval is logged in YAML front matter with reviewer identity and timestamp. This approval record becomes the audit trail.

5. The VDA Customer Journey Model

5.1 The Two-Axis Governance Map

The VDA industry customer journey model is an organisational accountability architecture — the mechanism by which the RACI for AI governance is encoded into the file structure itself rather than maintained as a separate spreadsheet.

The framework establishes a two-axis governance map. The vertical axis represents customer-facing value streams — the journey stages that define how the organisation delivers its proposition to customers. The horizontal axis represents the universal operational engine — the three shared service value streams that sustain every business regardless of industry. Every AI agent sits at a specific intersection of these two axes.

5.2 Vertical Journey Stages

The following table uses the hospitality proof-of-concept as illustration. The same structure applies to any industry — the domain owners, journey stages, and descriptions are replaced with the industry equivalent.

Journey Stage	Domain Owner	Description
Pre-Book	Marketing Director	AI agents governing discovery, availability queries, pricing display, and initial engagement
Book	Revenue Manager	AI agents governing reservations, payment capture, confirmation workflows, and upsell offers
Stay	Operations Director	AI agents governing check-in, room management, guest requests, service delivery, and complaint handling
Post-Stay	CX Director	AI agents governing checkout, review solicitation, loyalty crediting, and re-engagement campaigns
Shared Services: Legal	General Counsel	Cross-cutting legal constraints inherited by all vertical agents
Shared Services: Finance	CFO	Financial authority limits and approval thresholds inherited across all stages
Shared Services: HR	CHRO	People-related governance inherited by all agents with people-facing actions

5.3 The Cross-Domain Inheritance Rule

A vertical agent cannot execute an action that crosses into a Shared Services domain without inheriting explicit permission from the relevant Shared Services Markdown files. This is not a policy written in a separate governance document — it is structurally enforced by the agent's instruction files at runtime. The Witness Agent logs every cross-domain inheritance check, creating an automatic audit trail that demonstrates the governance structure was actually applied, not just documented.

R
A
C
I

The RACI emerges from the file structure automatically. Finance owns all S2P-* and O2C-* files. HR owns all HRpay-* files. The intersection points — where a vertical agent invokes a shared service rule — are exactly where cross-functional approval is architecturally required. No RACI

spreadsheet needs to be maintained separately. A cross-domain inheritance event (COMPLIANCE_BOUNDARY/INFO) is written to the Witness trail whenever this applies.

6. The Three Universal Horizontal Value Streams

6.1 Why These Three

Source-to-Pay, Order-to-Cash, and Onboarding-to-Final-Pay share a property that makes the C2MD baseline model particularly powerful: they are structurally identical across all organisations in the same industry at the 80-85% level. This structural universality means pre-built C2MD baselines for these three value streams can be genuinely comprehensive before a single customer document is ingested.

Value Stream	Baseline Anchors	Exception Delta Captures
Source-to-Pay (S2P)	NIST SP 800-53 SA-4, APQC Category 4.0, CIPS standards, three-way match controls	Approval authority thresholds, preferred supplier lists, country-specific payment terms, emergency procurement
Order-to-Cash (O2C)	NIST SP 800-53 AU-2, APQC Category 2.0, PCI DSS controls	Customer-specific pricing tiers, strategic account credit limits, territory-specific billing, dispute resolution authority
Onboarding to Final Pay (HRpay)	NIST SP 800-53 AC-2, GDPR Article 5, ISO 42001 human oversight	Local statutory variations, grade-specific benefits, collective agreement deviations

7. Domain Ownership, RACI, and Exception Management

7.1 The Machine-Enforced RACI

Traditional RACI matrices are governance theatre: consultants produce them, executives approve them, and then they sit in SharePoint while actual decision-making follows informal patterns that nobody documents. The VDA-MD Framework replaces the RACI spreadsheet with a machine-enforced RACI encoded in the YAML front matter of every Markdown file:

```
control_id: S2P-approval-authority
domain: Shared Services / Finance
owner: CFO # Accountable
authored_by: Head of Procurement # Responsible
consulted: [Legal, CISO] # Consulted
informed: [COO, Compliance Officer] # Informed
approved_by: CFO
approved_date: 2026-03-18
expires: 2027-03-18
risk_level: high
nist_control: SA-4
mustCount: 6 mustNotCount: 5 mayCount: 1
```

When an exception is proposed, the workflow engine reads the YAML metadata of the relevant baseline file to determine the approval chain automatically. Governance file compliance posture is tracked as structured database fields — MUST, MUST NOT, and MAY clause counts per file — making the compliance floor mathematically verifiable.

7.2 Exception Lifecycle Management

Every exception in the VDA-MD Framework is subject to a formal lifecycle with four mandatory stages: Proposal (domain owner specifies baseline deviation, conditions, business justification, expiry, and risk criteria), Sandbox Validation (run against synthetic scenarios for human review), Approval Routing (YAML metadata determines approval chain automatically, all approvals time-stamped), and Expiry Management (mandatory expiry date, 30-day warning, automatic baseline reinstatement on non-renewal).

COMPLIANCE INSIGHT

The exception lifecycle produces compliance evidence as a byproduct of operations. Every approved exception has a dated approval record, a risk acceptance statement, and a sandbox validation log. When an auditor requests proof that exceptions are properly controlled, the VDA dashboard produces the complete evidence trail automatically — not from a separate compliance system, but from the governance system that runs daily operations.

7.3 The Witness Agent

The Witness Agent runs in parallel with every operational AI agent in the VDA-MD system. It does not make decisions — it observes and records. For every agent action, the Witness Agent writes a structured entry to the domain's audit log recording: timestamp and agent identity, the action proposed and taken, every Markdown file consulted with specific clauses referenced, cross-domain inheritance checks and outcomes, human approval workflow triggers and

responses, the final decision and rule basis, and the live system data state at decision time — independently verifiable.

This log is not generated for auditors — it is generated as a natural side-effect of how the agent operates. This is Evidence-as-Code: compliance proof generated continuously, not assembled retrospectively.

8. Cryptographic Agent Identity — W3C Verifiable Credentials

Version 4.0 adds a cryptographic identity layer ensuring agents cannot operate with stale, revoked, or impersonated identities. Every agent on the platform holds a W3C Verifiable Credential (VC) binding its identity to the exact governance files it was authorised to operate under.

8.1 How It Works

Component	What	Detail
Issuer	The platform acts as VC issuer	Identified by platform DID
Subject	Each agent by canonical agentId	e.g., did:vda-md:checkin-agent
Governance Hash	SHA-256 of AGENTS.md + SOP.md + SKILL.md	Computed at issuance time
Expiry	23 hours after issuance	Automatic rotation cycle
Signing	HMAC-SHA256, server-side secret	Base64url-encoded result
Storage	agent_credentials table	One active credential per agent/company pair

8.2 Governance Hash Binding

When a VC is issued, the platform computes a SHA-256 hash over the combined content of the agent's AGENTS.md, SOP.md, and SKILL.md files. This hash is embedded in the credential. At every subsequent agent invocation, the middleware verifies the signature and expiry, then re-hashes the current governance files. If the hash differs from the VC's governanceHash, the governance files changed since credential issuance — a FRAMEWORK_INTEGRITY/FAIL Witness event is written and the discrepancy is permanently recorded in the audit trail.

This is the critical security property for enterprise CISOs: an agent cannot silently operate under stale governance. If a domain owner updates an AGENTS.md or SKILL.md, the hash changes, and the next credential verification catches it immediately — before any AI decision is made.

8.3 A2A Integration

The VC layer and A2A Protocol are complementary. A2A defines the communication channel between agents (the transport layer). W3C VCs define the identity and authorisation of the agent making the request (the trust layer). When an external agent arrives via A2A, it presents its VC as a Bearer token. The middleware verifies the credential before the A2A handler processes the task. This means the trust layer is enforced regardless of how the agent reached the endpoint.

9. A2A Protocol — External Agent Interoperability

Version 4.0 implements Google DeepMind's Agent-to-Agent (A2A) Protocol — an open standard for inter-agent communication using JSON-RPC 2.0 over HTTP. This layer enables external AI agents — built on any framework, from any organisation — to discover VDA-MD governed agents, submit tasks, and receive structured responses through a standards-compliant interface.

9.1 Transport Versus Trust

A2A provides the transport channel. W3C Verifiable Credentials provide the trust layer. These are sequential: an external agent reaches VDA-MD via A2A, then presents its VC before the §2.1 governance check fires, before the LLM is called, and before any external API is invoked. Neither layer replaces the other. The separation is intentional and architecturally significant.

9.2 A2A Core Concepts

Component	What It Is	How VDA-MD Uses It
Agent Card	JSON document at <code>/.well-known/agent.json</code>	Describes agent identity, capabilities, endpoint, and authentication requirements. External agents discover VDA-MD agents via Agent Cards.
Task	Core A2A work unit	Contains id, sessionId, status (submitted/working/completed/failed), input message, and output artifacts.
JSON-RPC 2.0	Message envelope	All A2A requests use the tasks/send, tasks/get, or tasks/cancel methods with standard JSON-RPC envelope structure.
Ajv v8 Validation	Schema validation on every message	Required fields, message structure, and parts format are validated before any processing occurs. Invalid messages return -32005 with specific validation errors.

9.3 The Governance Pipeline for A2A Tasks

When an external agent submits a task via A2A, the full VDA-MD governance pipeline fires identically to a native request:

- A2A message schema validated (Ajv v8) — invalid messages rejected with -32005.
- VC Bearer token verified — invalid or expired credentials rejected with -32004.
- §2.1 Enforcement Rule checked — missing governance files return -32001 before LLM is called.
- Agent decision pipeline executes — governance files loaded, Claude evaluates against MUST/MUST NOT clauses.
- Witness Agent seals the decision — full audit trail including A2A_PROTOCOL event category.
- Result returned as A2A artifact — structured task response with the agent's PASS/FAIL/ESCALATE decision.

An ESCALATE decision from an A2A task automatically triggers the HITL approval workflow (Section 10), returning JSON-RPC error -32003 to the external agent with the escalation reason.

9.4 A2A Error Codes

Error Code	Meaning
-32700	Parse error — invalid JSON
-32600	Invalid request — missing required fields
-32601	Method not found
-32001	Governance file missing — VDA-MD §2.1 violation
-32002	Agent not found in registry
-32003	Task rejected by governance evaluation (ESCALATE)
-32004	Credential verification failed (VC invalid or expired)
-32005	Schema validation failed (Ajv v8)
-32006	Self-onboarding not permitted

10. Agent Onboarding — The Self-Governing Framework

The most architecturally significant addition in version 4.0 is the Onboarding Agent — the 9th governed agent, which governs the admission of external agents into the VDA-MD framework. It uses the framework to govern itself: the same AGENTS.md, SOP.md, SKILL.md, Witness audit trail, and HITL approval gates as every other governed workflow in the system. The framework governs its own growth using its own rules.

10.1 The Seven-Phase Admission Workflow

Phase	Description	Key Gate
Phase 1 — Intake	External agent submits A2A tasks/send with Agent Card payload	VC verified, A2A message validated, onboarding record created
Phase 2 — Governance Analysis	Onboarding Agent analyses stated capabilities, governance model, integration scope	Agent's AGENTS.md, SOP.md, SKILL.md read to verify own governance envelope first
Phase 3 — Impact Delta Analysis	Deterministic analysis of what governance changes admission requires	Skill overlaps, ESCALATE friction, unexercised MAY clauses, RACI ambiguities — all without calling the LLM
Phase 4 — First HITL Gate	Impact Delta Report sent to domain owner and Compliance Officer for approval	Reject → terminate with Witness entry, no files written. Approve → proceed to sandbox.
Phase 5 — Adversarial Sandbox	Candidate SOP.md evaluated against 5 adversarial governance scenarios	Pass rate ≥ 0.95 required to proceed. Eval uses real operational data where available.
Phase 6 — Second HITL Gate	Decision card includes eval results — domain owner sees actual evidence	Approving commits governance files to production and issues a cryptographic credential to the new agent.
Phase 7 — Admission	GitHub PR created, VC issued, Agent Card registered, Witness entry: agent_onboarded	Rollback: revert PR. VC expires within 23 hours. No manual cleanup required.

10.2 Impact Delta Analysis — Upside and Downside

The Impact Delta Analyser is the core intelligence of the Onboarding Agent. It produces a structured report covering both the value a new agent could add and the risks it introduces — across all existing agents — before any candidate governance files are generated.

Upside Detection	Friction Removed: ESCALATE events in the last 30 days that the new agent could auto-resolve. Value Added: unexercised MAY clauses the new agent could activate. Cross-domain gaps the new agent could close.
Downside Detection	Skill Duplication: exact overlaps auto-removed from candidate SKILL.md with Witness log entry. MUST NOT Boundary Overlap:

	governance conflicts flagged for HITL exception. Authority Collision: financial threshold conflicts in Shared Services Finance SOP.md.
RACI Resolution	If domain ownership is clear from file structure, the correct approver is automatically identified. If ambiguous — cross-domain intersection with no single owner — both candidate owners are notified as a named exception. Onboarding is not blocked; the ambiguity is surfaced for human judgment.

The first HITL Decision Card includes a structured Impact Delta Report showing friction removed (with weekly escalation counts), value added, conflicts with resolution status, auto-removed skills, RACI exceptions, and the complete list of files to be created and modified. The second HITL Decision Card adds the adversarial sandbox eval results — pass rate, scenario details, and which clauses were tested.

10.3 Why This Answers the Watchers Question

The enterprise CISO question — who watches the watchers? — has a direct answer: the same framework, the same audit trail, the same HITL gates, and Git change management that any production deployment requires. Agent addition is not a special privileged operation. It is a governed workflow with a complete audit trail, dual human approval, adversarial testing, and a one-command rollback. The Onboarding Agent cannot approve its own admission — a hardcoded MUST NOT in its SOP.md and a pre-LLM check that fires if the submitted Agent Card name equals onboarding-agent.

11. Witness Agent Governance Expansion

Version 4.0 extends the Witness Agent from recording agent decisions to recording everything that affects how agents are allowed to behave — governance file changes, framework integrity events, agent lifecycle transitions, compliance boundary crossings, and A2A protocol events. This closes the gap between an audit trail and a governance control.

11.1 Event Categories

Category	What It Covers	Example Events
AGENT_DECISION (null)	Standard agent decision (PASS/FAIL/ESCALATE)	Backwards compatible — existing entries display as Agent Decision
FRAMEWORK_INTEGRITY	Governance hash checks, integrity check runs, VC validation results	Compliance Guard rejections, 6-hour integrity check results, hash mismatches
COMPLIANCE_BOUNDARY	Events at the edge of compliance enforcement	Compliance Guard rejections, cross-domain inheritance invocations, exception lifecycle events
AGENT_LIFECYCLE	Agent identity and onboarding events	VC issuance, rotation, expiry, onboarding admission, rollback
A2A_PROTOCOL	External agent interaction events	A2A message receipt, schema validation results, admission decisions
DATA_GOVERNANCE	Reserved for future data lineage events	Governed Data Bridge exports/imports (future capability)

11.2 Automatic Governance Event Emission

The platform writes governance events automatically across all system components. Every event is written by `writeGovernanceEvent()` — a strict variant of the witness writer that requires `event_category` and defaults decision to INFO for lifecycle events that are not agent decisions.

Trigger	Category / Decision	What Is Recorded
A2A message received	A2A_PROTOCOL / INFO	Message receipt, schema validated
A2A schema validation failure	A2A_PROTOCOL / FAIL	Invalid message rejected with Ajv errors
Compliance Guard rejection	COMPLIANCE_BOUNDARY / FAIL	File edit rejected; lists specific violations including which MUST count was reduced
VC governance hash mismatch	FRAMEWORK_INTEGRITY / FAIL	Governance files changed since credential issue
VC credential rotation	AGENT_LIFECYCLE / INFO	Credential rotated for agent at company
Cross-domain inheritance invoked	COMPLIANCE_BOUNDARY / INFO	Finance O2C shared services files applied

Integrity check passed	FRAMEWORK_INTEGRITY / PASS	Per-agent hash verification confirmed
Integrity check failed	FRAMEWORK_INTEGRITY / FAIL	Missing file, hash mismatch, or cross-reference break detected
Agent onboarded	AGENT_LIFECYCLE / INFO	External agent admitted to VDA-MD framework
Agent offboarded / rollback	AGENT_LIFECYCLE / FAIL	Onboarding rolled back with reason and PR reference

11.3 The 6-Hour Governance Integrity Check

A background scheduler runs a full governance integrity check every 6 hours. It verifies that all three mandatory file types are present and non-trivial for every agent/company pair, recomputes governance hashes, checks cross-reference integrity between files, and writes structured FRAMEWORK_INTEGRITY Witness events for every pass and fail. A hash mismatch means a governance file was changed outside the normal PR/approval flow — the highest severity framework integrity event, automatically escalated to the file owner.

11.4 Framework Integrity Panel

The Witness Agent tab in the dashboard includes a Framework Integrity Panel above the audit trail, polling every 30 seconds. Four metric cards surface live compliance posture: Integrity Checks Passed (last 24h), Integrity Check Failures (all time), Compliance Guard Rejections (last 7 days), and Active Exceptions (live EXCEPTION.md files). A Recent Framework Events list shows the last 10 entries across FRAMEWORK_INTEGRITY, COMPLIANCE_BOUNDARY, and AGENT_LIFECYCLE categories. A category filter on the audit trail allows filtering by governance domain.

12. GDPR and EU AI Act: Compliance Built In

GDPR and the EU AI Act are not bolt-on considerations in the VDA-MD Framework — they are implemented as architectural properties. The framework's design decisions were made with both regulations in mind, and the technical mechanisms that enforce governance also satisfy the specific legal requirements of each. This section documents what is built, not what is planned.

12.1 GDPR: Technical Implementation

The General Data Protection Regulation's core principles are addressed at the architectural layer, not the policy layer. Each principle maps to a specific technical mechanism:

GDPR Requirement	VDA-MD Implementation	How It Works
Article 5 — Data Minimisation	Microsoft Presidio mandatory pre-ingestion layer	All documents pass through Presidio Analyzer before any content reaches the Claude API. Deterministic token replacement pseudonymises PII fields while preserving logical coherence for governance processing. No raw PII reaches Anthropic infrastructure.
Article 5 — Purpose Limitation	YAML front matter on every governance file	The owner, authored_by, consulted, informed, and approved_by fields encode the lawful basis and purpose for every governance file. The Witness Agent records the exact file and clause applied to every decision — purpose is documented at the point of use, not retrospectively.
Article 5 — Storage Limitation	Mandatory expiry on every EXCEPTION.md	Every exception carries a mandatory expiry date. Thirty days before expiry the system notifies the domain owner. If not renewed, the exception expires automatically and the baseline rule is reinstated. Governance files that carry personal context cannot persist indefinitely without active renewal.
Article 5 — Accountability	Witness Agent Evidence-as-Code	Every agent decision is logged with the exact governance file version, the clause applied, the live data context, and the identity of the domain owner who approved the governing rule. The audit trail is generated as a byproduct of operations — not assembled retrospectively for regulators.
Article 25 — Privacy by Design	Section 2.1 Enforcement Rule	Agents cannot operate without their full governance envelope. Privacy-relevant controls encoded in SOP.md files are enforced before the LLM is called. Privacy is a pre-condition of execution, not an afterthought.
Article 30 — Records of Processing	RACI in YAML front matter	The machine-enforced RACI encoded in every governance file's YAML front matter constitutes a structured record of processing activities: who is accountable, who is responsible, what data is processed,

		under which legal basis, and when the record was approved.
--	--	--

GDPR NOTE	The Presidio pre-processing layer reduces but does not eliminate GDPR obligations on the AI inference layer. Even pseudonymised data may carry regulatory obligations depending on jurisdiction and sector. For HRpay and O2C domains containing employee or customer personal data, the Shared Services: Legal SOP.md must encode the applicable retention and processing rules, and ZDR/BAA agreements with Anthropic must be confirmed before any document ingestion occurs.
------------------	---

12.2 EU AI Act: Technical Implementation

The EU AI Act imposes specific obligations on providers and deployers of high-risk AI systems around transparency, human oversight, record-keeping, and risk management. VDA-MD satisfies these obligations through the same mechanisms that enforce governance — not through separate compliance tooling.

EU AI Act Requirement	VDA-MD Implementation	How It Works
Article 9 — Risk Management	risk_level in YAML front matter + Compliance Guard	Every governance file carries a risk_level field (low/medium/high). High-risk actions require explicit domain owner approval and Shared Services inheritance. The Compliance Guard prevents governance files from being weakened without formal named sign-off — risk management is enforced at the file level, not just documented.
Article 12 — Record-Keeping	Witness Agent audit trail	Every agent decision is recorded with: the exact MUST/MUST NOT/MAY clause, the governance file name and version, all files consulted, the live data state at decision time, and the escalation target. Records are generated continuously in a tamper-evident two-repository architecture. The SOC 2 System Description Generator auto-produces auditor-ready documentation directly from live governance files and Witness Agent data.
Article 13 — Transparency	Human-readable Markdown governance files	The governance files that control every AI agent decision are readable by the VP of Operations, the Compliance Officer, or the General Manager without technical training. Transparency is not a reporting layer — it is the source of truth. Any person with access to the governance repository can read exactly what rules govern every agent decision.
Article 14 — Human Oversight	Section 2.1 Enforcement Rule + HITL gates	Agents cannot operate outside their governance envelope by construction. High-risk decisions require human approval via structured HITL decision cards before execution. The dual-gate approval in the

		Onboarding Agent — first gate approves intent, second gate approves adversarial evaluation evidence — is the highest expression of Article 14 compliance in the framework.
Article 16 — Provider Obligations	C2MD pipeline + human approval gate	The mandatory human approval gate — where the Compliance Officer reviews and approves every baseline file before deployment — satisfies the provider obligation to ensure AI systems perform as specified. If the source compliance document is required to understand the generated file, the translation has failed.
Article 17 — Quality Management	Adversarial governance sandbox	Candidate governance files are evaluated against adversarial scenarios (95% pass rate required) before production deployment. Where production operational data is available, the sandbox uses real pseudonymised Witness entries rather than synthetic scenarios — constituting a structured quality management process for governance changes.

12.3 The Compliance Stack in Practice

GDPR and the EU AI Act interact in the VDA-MD context because many agents that make consequential decisions also process personal data. The framework addresses this intersection explicitly:

- The HRpay value stream is the most heavily regulated intersection: employment law, GDPR employee data obligations, and EU AI Act high-risk classification for AI systems affecting employment all apply simultaneously. Any exception to the HRpay baseline requires Shared Services: Legal inheritance and mandatory human-in-the-loop approval — both GDPR and AI Act obligations are enforced by the same governance mechanism.
- The O2C value stream (customer data, payment processing) requires both GDPR lawful basis documentation encoded in Shared Services: Legal SOP.md and EU AI Act transparency obligations satisfied by human-readable governance files. PCI DSS controls for payment data handling are encoded in the O2C baseline.
- The Witness Agent event category COMPLIANCE_BOUNDARY captures every cross-domain inheritance invocation — the precise moment at which an operational agent touches a regulated data domain. These events constitute the record of processing activities required under both GDPR Article 30 and EU AI Act Article 12.
- The Framework Integrity Panel's six-hour integrity check means compliance posture is monitored continuously. FRAMEWORK_INTEGRITY/FAIL events surface immediately to platform operators, satisfying the proactive risk management obligations of both regulations.

COMPLIANCE POSTURE

The VDA-MD Framework does not claim to make an organisation fully GDPR or EU AI Act compliant — legal compliance depends on specific processing activities, jurisdictions, and organisational context. What the framework provides is the technical infrastructure through which compliance obligations can be encoded, enforced, monitored, and evidenced at the operational layer — by the domain



owners who understand the business, not by compliance teams who review dashboards after the fact.

13. Product Architecture: Standalone and Enterprise

12.1 The Complete Technology Stack (v4.0)

Layer	What It Is	What It Provides
Governance	VDA-MD with Compliance Guard and §2.1 Enforcement	Markdown files as sole source of truth for all agent behaviour
Identity	W3C VC with 23-hour rotation and governance file hash binding	Cryptographic binding of agent identity to governance file version
Transport	A2A JSON-RPC 2.0 with Agent Card discovery and session management	Standards-compliant external agent interoperability
Output	Structured JSON-RPC responses with Ajv v8 schema validation	Type-safe, schema-validated responses on every A2A interaction
Eval	Adversarial governance sandbox (≥0.95 pass rate required)	5-scenario adversarial SOP evaluation against operational data where available
HITL	Decision cards with dual-gate approval and direct phase transition	Human approval gates integrated into the agent decision pipeline
Lifecycle	Onboarding Agent with 7-phase orchestration, impact delta, rollback	Self-governing framework growth with complete audit trail
Audit	Categorised Witness Agent with 6-hour integrity check and integrity panel	Evidence-as-Code generated continuously across all governance domains

12.2 VDA-MD Standalone: For SMBs and Mid-Market

The VDA-MD standalone product is designed for organisations of 5 to 500 people who need AI governance and operations but do not have enterprise infrastructure teams, platform engineers, or dedicated compliance departments. The standalone configuration is designed for organisations whose AI governance risk profile is primarily operational rather than regulatory.

Component	Technology	Rationale
AI Reasoning	Claude API (Anthropic)	C2MD translation, agent reasoning, gap analysis, exception drafting
PII Pre-processing	Microsoft Presidio (MIT)	Mandatory pre-ingestion PII detection and pseudonymisation. No PII reaches Anthropic infrastructure.
Document Ingestion	Microsoft MarkItDown (MIT)	Converts PDFs, DOCX, XLSX, PPTX into clean Markdown after Presidio processing.
Governance Ledger	GitHub private repository	Immutable version history under full branch protection: force-push disabled, PR required, GPG-signed commits.
Audit Ledger	GitHub private repository (separate)	Witness Agent append-only writes via dedicated service account. Separate from governance repo for real-time logging.

Compliance Guard	API-layer enforcement	Every governance file save rejected with 409 Conflict if it reduces MUST counts, removes NIST references, or deletes ISO 42001 citations.
Adversarial Sandbox	Isolated simulation environment	Generates structured scenarios for human review before exception approval. Human sign-off is the validation gate.
Cryptographic Identity	W3C VC layer	23-hour rotation cycle, governance hash binding, automatic FRAMEWORK_INTEGRITY events on hash mismatch.
A2A Protocol	JSON-RPC 2.0, Ajv v8	External agent interoperability with schema validation on every incoming message.

ZDR NOTE

Anthropic's standard API terms do not include Zero Data Retention (ZDR). For organisations whose ingested documents contain regulated data categories, ZDR and Business Associate Agreements (BAA) must be contracted separately with Anthropic before any document ingestion occurs. The Presidio pre-processing layer reduces but does not eliminate this requirement — even pseudonymised data may carry regulatory obligations depending on jurisdiction and sector.

12.3 A-VDA-Wrapper: The Enterprise Configuration

For enterprise deployments, the VDA-MD governance layer integrates with the A-Wrapper V2 execution engine. In this configuration, the .md files produced by C2MD feed a subsequent step that generates OPA Rego policies for deterministic, fail-closed enforcement at the network layer via the Semantic Firewall, while preserving the Markdown as the human-readable source of truth that business owners can read and edit without engineering intervention.

12.4 The Upgrade Path

The upgrade path from standalone to enterprise is non-destructive. An organisation that starts on VDA-MD standalone — building its .md governance library, training its domain owners to author and own their files, operating its Witness Agent, and building its agent credential infrastructure — does not discard that investment when it grows into enterprise-scale deployment. The .md files port directly. The RACI metadata ports directly. The organisation moves from Claude-as-runtime-engine to OPA-Rego-as-deterministic-enforcement without rewriting its governance logic — because the governance logic was always in the Markdown.

14. Proof of Concept: Hospitality Industry Validation

13.1 Scope and Status

The core POC has been executed as a functioning platform — VDA-MD (Value Driven AI Management Kit) — built on top of the Apaleo Property Management System and validated against Apaleo's sandbox environment. The platform is not a simulation: every agent call hits Apaleo's real MCP endpoint, and every Witness Agent entry contains real Apaleo reservation IDs, folio IDs, and rate plan IDs that can be independently verified in the Apaleo sandbox portal.

Five citizenM hotel properties are configured as fully independent governance domains — Berlin, London, Munich, Paris, and Vienna — each running nine AI agents governed by a canonical stack of 29 Markdown governance files. The choice of Apaleo as the underlying system of record is deliberate: governing AI agents against a production-grade hospitality PMS rather than a synthetic test environment validates that the framework operates under real operational constraints.

The live implementation is accessible at value-driven-ai-md-apaleo.replit.app

Hospitality is the proof-of-concept vertical. The framework's architecture — the two-axis governance map, the three universal value streams, the MUST/MUST NOT clause structure, the exception lifecycle, the Witness Agent, and all capability layers added in v4.0 — applies identically to any industry with a defined customer journey.

13.2 The Nine Agents

Agent	Stage / Domain	Key Tools	Decision Authority
Availability Agent	Pre-Book / Revenue	GetAvailableUnitGroups, ListRatePlans	Confirms real unit count against live inventory
Rate Agent	Book / Revenue	ListRatePlans	Autonomous rate override $\leq 9\%$ below BAR; escalates above
Reservation Bot	Book / Revenue	CreateBooking, GetGuestProfile	Creates/amends reservations after PASS
Check-In Agent	Stay / Operations	CheckIn, GetReservation, ListFolios	5-gate validation (ID, folio, payment, status, arrival)
Folio Charge Agent	Stay / Finance	CreateFolioCharge, GetFolio	Posts charges; autonomous $< \text{€}200$, sign-off required $\geq \text{€}200$
Folio Agent	Stay / Finance	GetFolio, ListFolios	Reads and validates folio state, flags anomalies
Checkout Agent	Post-Stay / Operations	CheckOut, ListFolios	Departure processing with loyalty exception evaluation
Revenue Reconciliation	Post-Stay / Finance	GetReport, ListFolios	$\leq 5\%$ variance = autonomous PASS; flags larger discrepancies
Onboarding Agent	A2A / Platform	No Apaleo tools	Governs external agent admission via 7-phase workflow

13.3 The 7-Step Live Scenario

The centrepiece interactive demo runs a complete guest journey through all operational agents in sequence against live Apaleo data. Before any scenario runs, the platform sets 60 days of nightly rates on the demo rate plan via the Rates PUT endpoint, creates a fresh Confirmed booking 7 days in the future, and resolves the folio automatically. All agents operate against this guaranteed live Apaleo data — no mocked responses anywhere in the pipeline.

S te p	Agent	Apaleo Tool	Decision Logic
1	Availability Agent	GetAvailableUnitGroups	Confirms real unit count against live inventory
2	Rate Agent	ListRatePlans	Approves 5% discount autonomously (BAR €180 → €171, under 9% ceiling)
3	Reservation Bot	GetGuestProfile	Verifies demo reservation exists in Apaleo live environment
4	Check-In Agent	CheckIn (MCP)	Transitions reservation from Confirmed to InHouse
5	Folio Charge Agent	CreateFolioCharge (MCP)	Posts €89 RoomRevenue charge to real folio
6	Checkout Agent	CheckOut (MCP)	Applies Gold loyalty exception: 13:00, €30 fee waived, exceptionApplied: true
7	Revenue Reconciliation	GetReport / ListFolios	Reconciles folio vs rate plan; seals audit trail

13.4 Validation Findings

The VDA-MD implementation validated all three core hypotheses: C2MD translation quality (governance files confirmed accurate by domain review without reference to NIST source documents), exception overlay reliability (Gold loyalty exception correctly overrides baseline for qualifying guests and reverts immediately for non-qualifying ones), and audit trail sufficiency (Witness Agent entries accepted by domain review as sufficient evidence of governance compliance).

Two unanticipated architectural findings emerged: the Compliance Guard (deterministic enforcement of governance file integrity at the application layer without OPA infrastructure) and the §2.1 Enforcement Rule (hard gate that prevents AI from operating outside its governance envelope, enforced before the LLM is ever called). Both findings strengthen the framework's security posture considerably and apply across all four new capability layers in v4.0.

15. Competitive Positioning

14.1 Market Landscape

Category	Key Players	Why They Do Not Compete
Enterprise GRC Platforms	Vanta, Drata, Credo AI, OneTrust	Passive monitoring tools. Cannot generate governance rules, govern AI agents, or be operated by non-technical domain owners.
AI Gateway Vendors	Traefik Hub, Bifrost, Kong AI Gateway	Network-layer traffic control. Govern agent access to tools but not agent behaviour within those tools.
Enterprise AI Orchestration	Palantir AIP, IBM Watsonx, Beam AI	Heavy engineering overhead. Require dedicated teams. Not accessible to domain owners without technical expertise.
Copilot Builders	MS Copilot, Custom GPTs	No governance structure. High hallucination risk. No domain separation, no RACI, no audit trail, no cryptographic identity.

14.2 The VDA-MD Differentiation

The VDA-MD Framework occupies uncontested ground at the intersection of four requirements that no existing product satisfies simultaneously:

- Governance files that a non-technical domain owner can read, edit, and own — not dashboards, not Rego policies, not YAML configurations.
- Compliance standards (NIST, ISO, APQC) as the automatic baseline — not a blank canvas that the organisation must fill from scratch.
- The customer journey with business logic separated as the organisational accountability architecture — embedding the RACI in the file structure rather than maintaining it separately.
- Cryptographic identity binding that ties every agent decision to the exact governance file version it was authorised to operate under — verifiable, tamper-evident, and automatically monitored.

The Baseline-plus-Delta model is the specific innovation that creates durable competitive advantage. Every competitor is building ingestion-first platforms that require organisations to document everything. The VDA-MD requires organisations to document only their exceptions — which is faster to deploy, cheaper to maintain, and creates a cleaner, more auditable governance record.

14.3 The Format Advantage and Vendor Independence

By standardising on Markdown as the governance primitive, the VDA-MD Framework ensures that organisations own their governance logic in perpetuity, in a format that is independent of any vendor, platform, or technology stack. The .md files that constitute an organisation's governance library are plain text. They can be read by any text editor, versioned by any Git provider, consumed by any LLM, and migrated to any future platform without conversion. The organisation's investment in building a high-quality governance library does not depreciate when platform decisions change.

16. Implementation Roadmap

Phase 0: Foundation

- Initialise two GitHub private repositories: governance repo (full branch protection, PR-gated, GPG-signed commits) and audit repo (Witness Agent service account, append-only, force-push disabled). These configurations are mandatory prerequisites for SOC 2 and EU AI Act audit trail compliance.
- Configure Microsoft Presidio Analyzer as mandatory pre-ingestion PII processing layer. Define document classification: safe to ingest as-is (structural policy documents), requires redaction before ingestion (documents containing named individuals or account-specific terms), never ingest directly (payroll data, individual employee records, customer PII, payment credentials).
- Configure MarkItDown MCP server and validate document conversion pipeline downstream of Presidio.
- Load NIST OSCAL SP 800-53 Rev 5 catalog and ISO 42001 as C2MD source references.
- Configure Claude API access and confirm ZDR/BAA status with Anthropic for any regulated document categories.

Phase 1: C2MD Baseline Generation

- Run C2MD translation for 8-10 NIST controls relevant to the target vertical.
- Generate S2P, O2C, and HRpay baseline files from APQC and NIST sources.
- Compliance Officer review and approval of all generated baselines — human sign-off mandatory. Validate that domain owners can read and understand all baseline files without assistance. If source documents are required, the translation has failed.
- Commit approved baselines to governance repo with reviewer metadata in YAML front matter.

Phase 2: Delta Ingestion

- Classify all source documents using the three-category framework (safe / redact first / never ingest).
- Run amber-category documents through Presidio pre-processing before MarkItDown ingestion.
- Domain owner review and approval of all logic, governance files, and classified documents.
- Exception .md creation for all identified deviations, with full RACI metadata and mandatory expiry dates.

Phase 3: Agent Deployment and Witness

- Deploy first operational agent in the lowest-risk journey stage.
- Activate Witness Agent with structured audit log generation for all agent decisions.
- Issue W3C Verifiable Credentials for all deployed agents. Configure 23-hour rotation scheduler.
- Configure A2A Agent Card registry and publish discovery endpoints.
- Deploy Onboarding Agent governance files and activate 7-phase admission workflow.
- Activate 6-hour governance integrity check scheduler.
- Present first audit log sample to Compliance Officer for evidence quality validation.

Staged deployment is possible by making exceptions for Human In the Loop (HITL) until comfort and accuracy is reached, and then exceptions can be baselined.

17. Conclusion

The VDA-MD Framework represents a fundamentally different answer to the enterprise AI governance problem — one grounded in the practical reality of what enterprise technology adoption actually requires, and recognising the massive enterprise investment in compliance, security, and business logic that is now, in many regards, Legacy.

The core architectural insight is not novel, but its systematic application to AI agent governance is: establish global best-practice standards as the automated baseline, and govern only what makes each organisation genuinely unique. Building best practice into the solution and flavouring for the secret sauce is an approach that works at enterprise scale with enterprise budgets. Selective digitisation of the genuine delta is both faster to deploy and creates a cleaner, more auditable governance record. Where the delta is lacking, the HITL domain expert is the gate.

Version 4.0 adds four capability layers that do not compromise this principle — they strengthen it. Cryptographic identity binding means governance cannot silently drift. A2A interoperability means the governed framework can extend to external agents without sacrificing the governance envelope. The self-governing Onboarding Agent means framework growth is itself governed by the same rules as everything else. The categorised Witness Agent and 6-hour integrity check mean the framework monitors itself continuously and surfaces compliance posture in real time.

The adversarial governance sandbox — evaluating candidate agents against real operational data where available, pseudonymised through Presidio before crossing environment boundaries — means the confidence a human approver places in a governance decision is grounded in evidence, not assertion.

Together, these additions answer the enterprise sceptic's questions directly: the framework cannot be silently weakened (Compliance Guard and FRAMEWORK_INTEGRITY events), agents cannot operate with stale governance (VC hash binding and automatic mismatch detection), external agents cannot bypass the governance envelope (A2A gated by VC authentication and §2.1 enforcement), and the framework's own growth is governed by the framework itself (Onboarding Agent with dual HITL and adversarial evaluation).

Organisations that deploy this framework early will not merely achieve AI governance compliance. They will build a structured, auditable, continuously improving record of how their business makes decisions — expressed in a format that every AI system they ever deploy can understand and act upon. That is not a compliance investment. That is an AI organisational operating system.

<https://value-driven-ai-md-apaleo.replit.app/>

NEXT STEP

Execute Phase 0 foundation setup as specified in Section 15. Two-repository architecture is mandatory before Witness Agent activation. Presidio PII layer is mandatory before any document ingestion. Confirm Anthropic ZDR/BAA status before ingesting regulated document categories. Live implementation reference: value-driven-ai-md-apaleo.replit.app

Appendix A: Glossary

A2A Protocol — Google DeepMind's Agent-to-Agent Protocol — a JSON-RPC 2.0 over HTTP standard for inter-agent communication. VDA-MD implements A2A as the transport layer for external agent interoperability. Distinct from the trust layer (W3C VC).

A-VDA-Wrapper — The enterprise AI execution configuration combining the VDA-MD governance layer with the A-Wrapper V2 execution engine (AgentGateway, Qdrant, OPA, ArgoCD).

Adversarial Governance Sandbox — A structured evaluation environment that tests candidate agent governance files against adversarial scenarios (≥ 0.95 pass rate required). Uses real operational data pseudonymised via Presidio where available.

Agent Card — A JSON document served at `/.well-known/agent.json` that describes an agent's identity, capabilities, endpoint, and authentication requirements. Used by external agents for A2A discovery.

Baseline — The pre-configured, C2MD-generated Markdown representation of a NIST/ISO/APQC best-practice control. Applies to all agents by default. Must never be created by AI alone — human approval gate is mandatory.

C2MD — Compliance to Markdown. A named, structured, repeatable methodology for translating machine-readable compliance standards into structured, human-readable, domain-owner-editable Markdown governance files.

C2P — Compliance to Policy. The existing OSCAL Compass framework (IBM/RedHat) that translates OSCAL into Kubernetes policy engine formats. In the VDA-MD enterprise configuration, C2MD and C2P are sequential stages.

Compliance Guard — API-layer enforcement that rejects any governance file save reducing MUST clause counts, removing NIST references, or deleting ISO 42001 citations. Returns 409 Conflict. Writes a COMPLIANCE_BOUNDARY/FAIL Witness event.

Cross-domain Inheritance — The architectural rule that a vertical agent cannot execute an action crossing into a Shared Services domain without explicitly inheriting permission from the relevant Shared Services Markdown files.

Delta — The organisation-specific exceptions, brand rules, and operational deviations from the baseline. Ingested via Presidio PII processing followed by Markdown.

Evidence-as-Code — Compliance audit evidence generated automatically as a byproduct of daily operations, not assembled retrospectively. The Witness Agent produces Evidence-as-Code continuously.

Exception — An approved deviation from a baseline rule, encoded in an EXCEPTION.md file with owner, approval chain, conditions, and mandatory expiry date.

Governance File Hash — SHA-256 hash of an agent's AGENTS.md + SOP.md + SKILL.md content, embedded in its W3C Verifiable Credential. Hash mismatch at verification time writes a FRAMEWORK_INTEGRITY/FAIL Witness event.

HITL (Human In the Loop) — A structured human approval gate triggered by ESCALATE decisions or governance lifecycle events. Implemented as time-bound decision cards with dual approval gates for high-risk decisions (e.g., agent onboarding).

Impact Delta Report — A structured analysis produced by the Onboarding Agent before any candidate governance files are generated. Covers friction removed (escalation reduction), value added (MAY clause activation), conflicts (duplication, boundary overlap, authority collision), and RACI exceptions.

Journey Stage — A named phase of the customer-facing value stream (e.g., Pre-Book, Book, Stay, Post-Stay in hospitality). Each stage has a designated domain owner and a specific set of governing Markdown files.

Onboarding Agent — The 9th VDA-MD agent. Governs external agent admission through a 7-phase workflow including impact delta analysis, dual HITL gates, adversarial sandbox evaluation, and full rollback capability. Cannot approve its own admission.

Presidio — Microsoft's open-source PII detection and anonymisation framework (MIT license). Mandatory pre-ingestion layer. Detects and pseudonymises personal data before any document content reaches the Claude API.

SKILL.md — The Markdown file type defining an agent's permitted capabilities. Each capability entry specifies the action permitted, the conditions and constraints, and the execution method. Distinct from SOP.md (governing policy) and AGENTS.md (scope and authority).

SOP.md — The Markdown file type defining the human-readable policy containing all MUST, MUST NOT, and MAY clauses that govern agent behaviour within a specific domain and journey stage.

Value Stream — An end-to-end sequence of activities that creates value. VDA-MD uses three universal horizontal value streams (S2P, O2C, HRpay) and vertical customer journey value streams specific to each industry.

Verifiable Credential (VC) — A W3C Verifiable Credential issued to each agent, binding its identity to the SHA-256 hash of its governance files at issuance. Rotates every 23 hours. Hash mismatch is detected and logged before any agent decision.

Witness Agent — A parallel monitoring agent that observes and logs every operational agent decision and governance event, producing a structured, tamper-evident audit log as Evidence-as-Code. In v4.0, events are categorised by governance domain.

writeGovernanceEvent() — The strict variant of the Witness Agent writer function. Requires `event_category` — will not compile without it. Used for all governance framework events (lifecycle, integrity, compliance boundary, A2A protocol). Distinct from `writeWitnessEntry()` which continues to handle agent decisions.

§2.1 Enforcement Rule — If any of the three mandatory files (AGENTS.md, SOP.md, SKILL.md) are missing for an agent/property pair, the system returns ESCALATE immediately — before the AI model is called and before any external API is invoked.

Appendix B: Standards References

Standard	Relevance to VDA-MD
NIST SP 800-53 Rev 5	Primary source for C2MD baseline generation across all operational domains. AC-2 (Account Management — VC-based agent identity, rotation), AU-2 (Event Logging — Witness Agent), AU-12 (Audit Record Generation — structured witness entries), SA-4 (Acquisition Process — governance file sign-off requirement), IR-4 (Incident Handling — ESCALATE path, HITL tokens).
NIST OSCAL (CSWP 53)	Machine-readable format providing structured control definitions as C2MD input.
NIST AI RMF	Risk management framework providing the governance structure that the VDA journey map implements organisationally.
ISO/IEC 42001	AI management system standard. VDA-MD baselines include ISO 42001 human oversight requirements for AI systems making consequential decisions. ISO 42001 citations are protected by the Compliance Guard.
APQC Process Classification	Industry-neutral process taxonomy providing the foundation for S2P, O2C, and HRpay baseline definitions.
EU AI Act	Regulatory framework requiring demonstrable governance for high-risk AI systems. The VDA-MD Evidence-as-Code approach directly satisfies Article 12 documentation and auditability requirements.
GDPR	Data protection regulation with direct relevance to HRpay and O2C domains. PII handling rules are encoded in Shared Services: Legal baseline files. Microsoft Presidio pseudonymisation layer satisfies the data minimisation principle at ingestion.
SOC 2 Type II	The Witness Agent audit log, two-repository tamper-evident architecture, Compliance Guard, and GitHub version history together provide the continuous evidence trail required for SOC 2 Type II certification.
W3C Verifiable Credentials	Cryptographic identity standard. VDA-MD uses W3C VCs to bind every agent's identity to the SHA-256 hash of its governance files, with 23-hour automatic rotation.
Google A2A Protocol	Agent-to-Agent Protocol (JSON-RPC 2.0). VDA-MD implements A2A as the transport layer for external agent interoperability, with Ajv v8 schema validation on every incoming message.
Kubicek (2026)	LLMs are directly trained on Markdown because a substantial portion of high-quality training data originates from GitHub, Stack Overflow, and technical documentation — Markdown provides semantic anchors that models can leverage. Referenced in Section 2.3.
AuditBoard / Pacific AI / McKinsey (2025)	Composite source for the 78% AI adoption vs 25-36% governance framework implementation gap cited in the executive summary and Section 1.